bradley.lab – Home Lab Notes

NIST SP 800-171 Gap Assessment Project | Malik Bradley

Lab Overview

Item	Detail
Host	Desktop PC, VMware Workstation Pro 26H1, 64 GB RAM, NVMe SSD (~1.3 TB free)
Domain	bradley.lab (NetBIOS: BRADLEY)
Network	VMnet2, Host-only, 192.168.100.0/24; no DHCP (static IPs); no gateway (isolated, no internet); host virtual adapter connected
File locations	C:\Labs\ISOs (installers), C:\Labs\VMs (virtual machines)

IP Plan

Host	Role	IP Address	Status
DC01	Domain Controller (Windows Server 2022)	192.168.100.10	Built
WS01	Workstation (Windows 11 Enterprise), domain-joined	192.168.100.20	Built
WAZUH	SIEM (Ubuntu Server 24.04)	192.168.100.30	Planned
KALI	Attacker / control testing (out of scope)	192.168.100.50	Planned
PFSENSE	Firewall (later phase)	TBD	Planned

Passwords are stored separately in a password manager. Do not record them in this document.

Session Log

2026-11-07 – Phase 1: Domain Controller

- Freed ~270 GB on host by removing leftover game and mod data.
- Downloaded evaluation ISOs: Windows Server 2022 (180-day) and Windows 11 Enterprise 26H2 (90-day).
- Created VMnet2 host-only network (192.168.100.0/24), DHCP disabled.
- Built DC01 VM: 4 GB RAM, 2 vCPU, 60 GB disk, NIC on VMnet2.
- Installed Windows Server 2022 Standard Evaluation (Desktop Experience). Snapshot: "Fresh Install."
- Installed VMware Tools.
- Set static IP 192.168.100.10/24, DNS 127.0.0.1, no gateway; verified with ipconfig.
- Renamed server to DC01. Snapshot: "Static IP + Renamed."
- Installed AD DS role and promoted to domain controller (new forest bradley.lab); verified with whoami → bradley\administrator.
- Snapshot: "Domain Controller – bradley.lab."

2026-11-08 – Phase 2: Directory Structure

- Created OUs: Admins, Lab Users, Workstations, Restricted-Workstations, Groups.
- Created security groups (Global) in Groups OU: Restricted-Data-Users, IT-Admins.
- Created users: malik, jsmith, adoe (Lab Users OU); malik.adm (Admins OU).

- Group membership: malik, jsmith → Restricted-Data-Users; malik.adm → IT-Admins + Domain Admins; adoe → none (negative test user).
- Domain password policy rejected a weak password during account creation (evidence for 3.5.7).
- Used fictional "Restricted-Data" label as a stand-in for CUI; all data simulated.
- Snapshot: "OUs, Users, Groups."

2026-11-08 – Phase 3: Workstation & Access Control Test

- Built WS01 VM (Windows 11 Enterprise Eval, 6 GB RAM, 2 vCPU, 64 GB, vTPM, NIC on VMnet2). Snapshot: "Fresh Install."
- Static IP 192.168.100.20/24, DNS 192.168.100.10; verified with ping (0% loss) and nslookup bradley.lab.
- Joined WS01 to bradley.lab using malik.adm; moved computer object from Computers container to Workstations OU (so GPOs can be linked).
- Domain login verified as BRADLEY\jsmith. Snapshot: "Domain Joined."
- Created C:\Restricted-Data on DC01 with FICTIONAL-Project-Falcon.txt; shared as \\DC01\Restricted-Data.
- NTFS: disabled inheritance, removed BRADLEY\Users, granted Restricted-Data-Users Modify (SYSTEM, Administrators, CREATOR OWNER retained). Share: removed Everyone, granted Restricted-Data-Users Change/Read.
- TEST PASSED: jsmith (authorized) opened \\DC01\Restricted-Data successfully.
- TEST PASSED: adoe (unauthorized) received "You do not have permission to access."
- Snapshot: "Access Control Test – Passed."

2026-11-08 – Phase 4: Group Policy Hardening

- Fixed WS01 time drift: w32tm /config /syncfromflags:domhier /update; w32tm /resync /force.
- Default Domain Policy: lockout threshold 5, duration 15 min, reset counter 15 min; minimum password length 12 (complexity enabled, history 24, reversible encryption disabled).
- Created and linked WS-Security-Baseline GPO to Workstations OU: logon banner (AUTHORIZED USE ONLY), machine inactivity limit 900 s, Advanced Audit (Logon, Credential Validation, User Account Management – Success/Failure).
- gpupdate /force and gpresult /r /scope computer confirmed both GPOs applied to WS01 (required UAC elevation even as Domain Admin).
- TEST PASSED: Logon banner displayed before sign-in on WS01.
- TEST PASSED: adoe locked out after 5 failed attempts (Windows 11 also added delay between attempts).
- Event 4740 (user account locked out, BRADLEY\adoe) recorded on DC01. Unlocked adoe in ADUC.
- Snapshot (both VMs): "GPO Baseline Applied."

Issues Found & Fixed

#	Issue	Fix	NIST 800-171
1	Time zone set to UTC-08:00 (Pacific) instead of Eastern	tzutil /s "Eastern Standard Time"	3.3.7
2	System clock ~3 hours ahead after promotion; time source was Local CMOS Clock and Settings locked on DC	Set-Date in PowerShell; enabled VMware Tools "Synchronize guest time with host"	3.3.7
3	Weak password rejected at account creation (policy working	Used compliant passphrase (12+ chars, mixed types, no	3.5.7

	as intended)	username)	
4	WS01 clock ~3 hours behind DC01 after domain join	Fixed: w32tm domain hierarchy sync + resync	3.3.7
5	Windows 11 eval ISO is an older build; license shows expired on install	Open: rebuild with current eval or Windows 10 Enterprise eval if forced shutdowns occur	N/A

Why it matters: Kerberos authentication fails when clock skew exceeds 5 minutes, and inaccurate time makes audit log timestamps unreliable for investigations.

Controls Demonstrated

Control	Requirement	Evidence
3.1.1	Limit system access to authorized users	adoe denied; jsmith allowed (screenshots)
3.1.2	Limit access to permitted functions	Group-based NTFS/share permissions
3.1.5	Least privilege	Only Restricted-Data-Users granted; BRADLEY\Users removed
3.1.6	Non-privileged accounts for non-security functions	malik (daily) vs. malik.adm (admin)
3.5.1	Unique identification of users	Named accounts, no shared logins
3.5.7	Password complexity and length	Min 12 chars, complexity on; weak password rejected
3.5.8 / 3.5.10	Password history; no reversible encryption	24 remembered; reversible encryption disabled
3.1.8	Limit unsuccessful logon attempts	adoe locked after 5 attempts; Event 4740
3.1.9	Security notice	AUTHORIZED USE ONLY banner
3.1.10	Session lock	900 s inactivity limit via GPO
3.3.1 / 3.3.2	Audit records traceable to users	Advanced audit enabled; 4740 names BRADLEY\adoe
3.3.7	Time synchronization	DC and WS01 clock issues found and fixed

Assessment Status (as of 2026-11-08)

14 Met, 2 Partially Met, 1 Not Met, 5 N/A, 29 Not Assessed. Open POA&M: POAM-01 MFA (3.5.3), POAM-02 privileged function auditing (3.1.7), POAM-03 central log collection (3.3.1).

Evidence folder: C:\Labs\Evidence\3.1-Access-Control

Observations (for Assessment)

- Windows Defender Firewall profile showed "Public" before promotion.
- "Unidentified network / No Internet" is expected on the isolated host-only network.
- A few auto-start services shown as stopped in Server Manager (benign in lab).
- Product not activated (evaluation, no internet) – expected.

Next Session – To Do (Phase 5: Detection)

- ☐ Build Ubuntu Server VM (192.168.100.30) and install Wazuh (temporarily NAT for internet)
- ☐ Install Wazuh agents + Sysmon on DC01 and WS01
- ☐ Build Kali VM (192.168.100.50); run brute-force against WS01 and confirm Wazuh alerts
- ☐ Close POAM-02 and POAM-03
- ☐ Assess Media Protection (3.8) family

Completed

- ☐ ✔️ Phase 1: Domain controller (bradley.lab)
- ☐ ✔️ Phase 2: OUs, groups, users
- ☐ ✔️ Phase 3: WS01 joined; access control test passed
- ☐ ✔️ Phase 4: GPO hardening; banner and lockout verified

Later Phases

Phase	Purpose
Wazuh + Sysmon	Detection; 3.3 Audit & Accountability
Kali brute-force tests	Validate 3.1.8 account lockout and Wazuh alerts
Nessus before/after scans	Vulnerability management and risk reduction evidence
pfSense firewall	Network segmentation and boundary protection
Free Azure tenant	Entra ID, Conditional Access, Intune
SSP + POA&M	Final deliverables; publish to GitHub (never include employer data)